INFORME DE DILIGENCIA DEBIDA DE RIESGOS V1.1 • ESTÁNDAR DE DEFENSA CRIPTOGRÁFICA

HAICHAIN: Informe de Diligencia Debida de Riesgos Institucionales

Demostraciones Matemáticas, Modelado de Amenazas y Matriz de Verificación Red-Team para Asignadores Tier-1

TARGET AUDIENCE	CRYPTOGRAPHIC SECURITY	PROTOCOL KERNEL
Tier-1 Venture Allocators & Audit Firms	Hardware Passkey • 9 Invariants Bound	HAICHAIN v1.1 • CapLeaf 223 Bytes

INFORME DE DILIGENCIA DEBIDA DE RIESGOS INSTITUCIONALES DE HAICHAIN

Demostraciones Matemáticas, Modelado de Amenazas y Matriz de Verificación Red-Team

Audiencia Objetivo: Firmas de Capital de Riesgo Tier-1 (a16z crypto, Paradigm, Sequoia), Custodios Institucionales y Firmas Auditoras de Primer Nivel (OtterSec, Neodyme, Kudelski Security)
Versión del Protocolo: HAICHAIN Kernel v1.1 / CapLeaf v1 (Esquema Wire de 223 Bytes)
Estándares: Anchor Framework (Solana L1) + Sui Move (`AgentCap`) + Solver de Intenciones Tron Rail

---

1. RESUMEN EJECUTIVO Y PARADIGMA DE SEGURIDAD

Los agentes autónomos de IA que ejecutan microtransacciones financieras presentan vectores de ataque radicalmente distintos a las finanzas descentralizadas tradicionales: 1. **Latencia Cero Sin Intervención Humana:** Un agente de IA que realiza llamadas a herramientas puede verse coaccionado mediante Inyección Indirecta de Prompt para emitir miles de vales de pago no autorizados en segundos. 2. **Vulnerabilidad de Filtración de Claves:** Ejecutar instancias de agentes en nodos distribuidos (Cloudflare Workers, MCPs locales, serverless) multiplica el riesgo de exfiltración de claves privadas. 3. **Proliferación de Comercios Sybil:** En una red M2M abierta, comerciantes maliciosos pueden registrar infinitos dominios desechables para eludir las limitaciones de tasa.

Para neutralizar esta amenaza sin sacrificar la ejecución en milisegundos, **HAICHAIN desvincula por completo la custodia de la ejecución financiera**: - **Autoridad Soberana Principal:** La llave biométrica de hardware Passkey FIDO2 WebAuthn (P-256) conserva el 100 % de la propiedad inmutable del fondo. - **Autoridad Aislada de Subagentes:** Los pares de claves Ed25519 efímeros se encuentran estrictamente aislados en un Motor de Políticas fuera de proceso, sin acceso a la frase semilla. - **Anclaje Merkle en Cadena:** El esquema de hoja de 223 bytes garantiza 9 invariantes matemáticos inmutables ($I_1 \dots I_9$).

---

2. MODELO FORMAL DE AMENAZAS Y FÓRMULAS DE LÍMITE DE PÉRDIDAS

2.1. Taxonomía de Superficie de Ataque

Clase de Amenaza	Escenario	Exposición Web3 Convencional	Límite Peor Caso HAICHAIN
T_1 (Inyección Indirecta)	LLM engañado para pagar a comercio no autorizado	Vaciado total de la billetera (**100,000+**)	**$E_{\text{theft}} = 0$** (Bloqueado por lista blanca Merkle)
T_2 (Colusión de Comercio)	Comercio legítimo intenta liquidar dos veces	Doble cargo en la cuenta de usuario	$E_{theft} = 0$ (Restricción Anchor $P_i \le \min(C_i, R_i)$)
T_3 (Ataque en Dominio de Prueba)	Subagente intenta agotar fondos en nueva API	Agotamiento progresivo del fondo	$E_{theft} \le M_{tpl}$ (Bloqueado por presupuesto padre)
T_4 (Compromiso Total del Agente)	Clave privada expuesta + comercio cómplice	Vaciado instantáneo de la totalidad del fondo	$E_{theft}(\tau) \le \min(B, K, W_p \cdot n(\tau, \omega_p))$

2.2. Teorema 6.1: Límite Superior de Robo en el Peor de los Casos (T_4)

Sea τ la latencia de respuesta total del protocolo desde que se inicia una transacción no autorizada hasta que la orden de congelamiento de emergencia (Panic Freeze) se confirma en cadena:

$$\tau = t_{detect} + t_{owner} + t_{land}$$

donde: - $t_{detect} \leq 5.0s$ (umbral de detección de anomalías por telemetría) - $t_{owner} \leq 2.0s$ (autorización biométrica de un toque con Passkey) - $t_{land} \leq 5.0s$ (inclusión de transacción de alta prioridad en Solana)

En el escenario extremo de compromiso total de la clave Ed25519 del agente y colusión con un comercio validado en el árbol Merkle, el robo máximo acumulado $E_{theft}(\tau)$ está acotado por:

$$E_{theft}(\tau) \leq \min(B,\; K,\; W_p \cdot n(\tau, \omega_p),\; \Sigma_{i:\, m_i \in \mathcal{A}} E_i(\tau))$$

Corolario: Para un fondo institucional con $10,000$ USDT, un tope por hoja de 50 USDT y un límite de velocidad de 10 USDT / hora, un atacante que comprometa la clave del agente **no podrá sustraer más de** 10 USDT antes de la congelación, preservando el **99.9% ($9,990$ USDT)** de los activos.

---

3. MATRIZ DE AUDITORÍA Y ENDURECIMIENTO RED-TEAM

Cinco vectores de ataque críticos han sido probados y mitigados en el núcleo: 1. **Doble Reclamación de Escrow:** Bloqueada mediante liquidación monótona irreversible. 2. **Secuestro de Cuentas ATA:** Imposibilitado por la derivación canónica estricta del Associated Token Account. 3. **Evasión de Congelamiento de Emergencia:** Eliminada mediante invalidación por época (I_6). 4. **Drenaje de Lamports de Alquiler:** Reembolso obligatorio y automático al fondo de origen (`grant_pot`). 5. **Ataque Sybil de Micro-Bucles:** Bloqueado por el consumo estricto del presupuesto plantilla padre.

---

4. INFORME DE AUDITORÍA DE LOS 9 INVARIANTES MATEMÁTICOS ($I_1 \dots I_9$)

Todas las instrucciones en `programs/haichain-core/src/lib.rs` satisfacen los 9 invariantes matemáticos: - I_1 (Conservación de Capital), I_2 (Seguridad de Destinatario Canónico), I_3 (Tope Presupuestario), I_4 (Límite de Velocidad Autónomo), I_5 (Estrechamiento Monótono PDA), I_6 (Aislamiento de Época Panic), I_7 (Expiración de Sesión Heartbeat), I_8 (Liquidación Monótona Única), I_9 (Aislamiento de Cuenta Anti-Sybil).

---

5. TOKENÓMICA Y CUMPLIMIENTO NORMATIVO

- **Cero Dividendos y Cero Rendimiento Pasivo:** Inmunidad absoluta frente a las pruebas de Howey y la normativa europea MiCA.
- **50% Recompra y Quema (Buyback & Burn):** Quema programática de $HAISI financiada por las tarifas de la red.
- **50% Fondo de Reserva del Protocolo (CHGB):** Respaldo para SLAs de proveedores y liquidación multired.

---

6. CONCLUSIÓN Y ACCESO A LA SALA DE DATOS (DATA ROOM)

HAICHAIN v1.1 establece la primera infraestructura de pago formalmente demostrada y protegida por hardware para la economía de agentes de IA.